Security Policy

Cosmaneura, Inc. — Cosma application

Version: 1.1 **Effective:** 2026-08-25 **Next review:** 2027-08-25 **Owner:** CTO / Security Lead

1. Purpose

This policy defines the security principles and minimum controls Cosmaneura applies to the Cosma application, its infrastructure, and the data it processes on behalf of customers. It exists to protect the confidentiality, integrity, and availability of customer data — including Protected Health Information (PHI) — and to align the engineering team on a shared baseline of secure practices.

2. Scope

This policy applies to:

- All production and staging environments of the Cosma application.
- All source code, configuration, and infrastructure-as-code managed by Cosmaneura.
- All Cosmaneura personnel (employees and contractors) with access to any of the above.
- All third-party sub-processors that receive customer data (enumerated in the Data Protection & Retention Policy).

3. Roles & responsibilities

Role	Responsibilities
CTO / Security Lead	Owns this policy, approves exceptions, leads incident response, signs off on new sub-processors.
Engineering team	Implements controls in code and CI, reviews pull requests, triages Sentry alerts and Dependabot findings.
All personnel	Follow this policy, use 1Password for secrets, enable MFA on all work accounts, report suspected incidents within 24 hours.

4. Security principles

- **Secure by default.** Every new feature is designed assuming untrusted input and hostile networks; controls (authN, authZ, encryption, validation) are the default path, not an opt-in.
- **Defense in depth.** No single control is relied upon; encryption, access control, monitoring, and code review each catch a different class of failure.
- **Least privilege.** Personnel, services, and tokens receive the minimum permissions required for their function.

- **Privacy by design.** PHI is de-identified via the Azure Health De-identification API before being sent to any third-party large-language-model service.

5. Minimum controls

Area	Control
Authentication (end users)	Delegated to Clerk; MFA supported.
Authentication (personnel)	SSO with MFA on GitHub, 1Password, Azure, Sentry, and Clerk admin.
Secret management	All secrets stored in 1Password, separated by environment vault (dev / staging / production / shared). No secrets in source.
Encryption in transit	TLS 1.2+ enforced for all ingress and outbound integrations.
Encryption at rest	Azure-managed encryption for PostgreSQL and Azure Blob Storage; application-layer AES-128 (Fernet) on sensitive columns such as Zoom OAuth tokens.
Webhook integrity	HMAC-SHA256 verification of Zoom webhook challenges; Redis-based replay protection (48 h dedup window).
Source control	Private GitHub repository; protected default branch; every change uses a pull request. Strict Tier 0 changes may auto-merge only after all required CI passes. Every other change requires human review. Tier 0 excludes governance, CI/workflows, dependencies, security or environment configuration, auth, billing, patient data, and other sensitive paths.
CI/CD gating	Automated lint (Ruff, ESLint), type checks (Pyright, TypeScript), migration safety (squawk-cli), and tests (pytest, Vitest) must pass before deploy.
Monitoring	Sentry (errors, traces) + structlog (structured JSON logs) + PostHog (product analytics); on-call rotation triages alerts.
Vulnerability management	See separate Vulnerability Management Policy.
Incident response	See separate Incident Response Policy.

6. Acceptable use

Personnel must not store customer data outside sanctioned systems (approved production infrastructure and approved analytics tooling). Copying production data to personal devices or to development databases is prohibited. Access to production systems requires MFA and is granted only to personnel with an active operational need.

7. Policy exceptions

Any exception to this policy must be documented, time-bounded, and approved in writing by the CTO. Exceptions are reviewed at each policy review cycle and either renewed or removed.

8. Review & revision

This policy is reviewed at least annually, or sooner when there is a material change to the architecture, the regulatory environment, or the threat model. Material revisions are versioned and recorded in the document header.

9. Contact

Security questions and disclosures: `dev@cosmaneura.com` · General: `info@cosmaneura.com`